

DPDPA Is No Longer Optional: What Every Indian Business Needs to Do Before May 2027

Article 1 - Compliance & Deadline Overview | Prepared for CoreGenix

For the past two years, India's Digital Personal Data Protection Act (DPDPA) has felt like something businesses could deal with "later." That window is closing fast.

With the DPDP Rules notified in November 2025, the countdown has officially begun. MeitY has set three enforcement dates: 14 November 2025, 14 November 2026, and 14 May 2027, with full substantive obligations, including penalties of up to ₹250 crore per violation, coming into force on the final date [1][2]. There is no indication of an extended grace period, and the Data Protection Board of India is already operational [1]. If your business collects, stores, or processes the personal data of customers, employees, or website visitors in India, this isn't a future compliance item. It's a live project with a hard deadline.

Why This Catches Businesses Off Guard

Most organisations assume data protection compliance is a legal checkbox: update a privacy policy, add a cookie banner, done. DPDPA is structurally different. Data Fiduciaries must provide itemised notices, define purpose-based retention timelines, implement reasonable security safeguards, and notify breaches within 72 hours [2]. It requires:

- Itemised, standalone consent, no more bundling permissions into one broad "I agree" checkbox
- Auditable proof of consent, durable, time-stamped records showing exactly what a user agreed to, not a retroactive reconstruction
- Breach notification within 72 hours to the Data Protection Board and affected individuals [2]
- Data Principal rights infrastructure, systems that let users access, correct, or request erasure of their data, and can prove it was honoured
- Consent Manager compatibility, provisions about Consent Managers become effective from 13 November 2026 [3]

None of this is a policy update. It's a systems and infrastructure project, legal requirements translated into technical architecture.

The Businesses Most at Risk

Two groups should be paying closest attention right now:

- **Significant Data Fiduciaries (SDFs)** - these organisations face enhanced obligations, including annual Data Protection Impact Assessments, independent audits, algorithmic fairness assessments, appointing a Data Protection Officer, and stricter technical due diligence [2].
- **Any business with legacy consent systems** - sign-up forms, cookie banners, IVR scripts, and paper-based onboarding flows built years ago- was never designed to integrate with an external Consent Manager registry. Retrofitting these systems takes far longer than most teams expect.

What Compliance-Ready Actually Looks Like

At CoreGenix, we look at DPDPA readiness as a build project with four pillars:

- Data discovery and mapping - knowing exactly what personal data you hold, where it lives, and who touches it
- Consent architecture rebuild - itemised notices, granular consent capture, and audit-ready logging
- Security safeguards - access controls, encryption, and monitoring aligned to DPDPA's "reasonable security" standard [4]
- Breach response readiness - a tested protocol, not a document sitting in a drawer

The Real Cost of Waiting

The 18-month runway from notification gives organisations a defined window to reassess their privacy posture and operational practices before the regime becomes fully binding [2]. Businesses that start now have time to test, fix, and refine. Businesses that wait until early 2027 will be racing a deadline with penalties attached, and building consent infrastructure under pressure rarely produces something durable.

DPDPA isn't just a legal risk anymore; it's an infrastructure decision. And infrastructure decisions take time to get right.

CoreGenix helps organisations build the IT infrastructure, security controls, and audit-ready systems that DPDPA compliance actually requires. If you haven't started mapping your readiness, now is the time.

References

[1] Shardul Amarchand Mangaldas & Co, "Enforcement of the DPDP Act and notification of the DPDP rules" — <https://www.amsshardul.com/insight/enforcement-of-the-dpdp-act-and-notification-of-the-dpdp-rules/>

[2] EY India, "DPDP Rules 2025 Notified by MeitY: Complete Guide" — https://www.ey.com/en_in/insights/cybersecurity/transforming-data-privacy-digital-personal-data-protection-rules-2025

[3] DLA Piper, "Data protection laws in India" — Data Protection Laws of the World — <https://www.dlapiperdataprotection.com/?t=law&c=IN>

[4] Apex Law Office LLP, "Digital Personal Data Protection Act 2023: Compliance & Data Breach Penalties 2026" — <https://legalfirm.in/digital-personal-data-protection-act-2023-compliance-data-breach-penalties-2026/>

DPDPA Compliance Isn't a Legal Problem, It's a Cybersecurity Problem

Article 2 - Technical & Cybersecurity Readiness | Prepared for CoreGenix

Most conversations about India's Digital Personal Data Protection Act (DPDPA) happen in legal and compliance teams. That's a mistake. The heaviest lift and the biggest risk sit squarely with IT and security.

Here's why: DPDPA doesn't just ask businesses to write better privacy policies. It requires organisations to prove, at any moment, that personal data is being processed securely, that consent was properly captured, and that breaches are detected and reported within strict timelines. That's not a legal deliverable. That's an infrastructure and security operations deliverable.

Full substantive obligations become enforceable on 14 May 2027, the final of MeitY's three notified enforcement dates [1]. The single largest financial exposure in the entire penalty schedule up to ₹250 crore per instance, is reserved for failing to implement "reasonable security safeguards" under Section 8(5) [4].

Where the Real Gaps Are

Having worked across IT infrastructure, cloud, and cybersecurity for enterprises, these are the gaps we see most often when businesses start their DPDPA readiness assessments:

- **1. No unified view of where personal data actually lives.** Data is scattered across CRMs, marketing tools, legacy databases, spreadsheets, and third-party vendors. You cannot secure or govern data you haven't mapped.
- **2. Consent capture that can't be audited.** A checkbox on a form isn't proof. DPDPA requires durable, time-stamped, itemised consent records, something most legacy sign-up flows, cookie banners, and IVR systems were never built to produce [2].
- **3. Security safeguards that don't meet the "reasonable security" bar.** Required measures include encrypting or masking personal data, appropriate access controls, and visibility through logs and monitoring to detect unauthorised access, with obligations that extend to any data processor acting on the fiduciary's behalf [4].
- **4. No tested breach response protocol.** DPDPA requires breach notification to the Data Protection Board and affected individuals without delay, with a detailed report due within 72 hours [2][4]. If your team has never run a breach simulation, you don't actually know if you can meet that deadline.
- **5. Systems that can't talk to the Consent Manager registry.** Provisions about Consent Managers take effect from 13 November 2026 [3]. Retrofitting old architecture for this is a multi-month project, not a quick patch.

Why 2026 Is the Year That Matters

The 18-month phased rollout gives organisations a defined runway to realign processes, systems, controls, and governance before enforcement becomes real [2]. The Data Protection Board of India is already operational, and there's no indication of an extended grace period once full enforcement begins [1]. Waiting until early 2027 to start means building critical infrastructure under deadline pressure, with far less room to test, fix, and get it right.

Where to Start

If your organisation hasn't begun its DPDPA readiness assessment, the starting point isn't a legal memo. It's a technical audit:

- Map every system that touches personal data
- Assess current consent capture and storage against DPDPA's evidentiary standards

- Run a gap analysis against the "reasonable security safeguards" requirement
- Build and test a breach notification protocol against the 72-hour timeline
- Plan Consent Manager API compatibility now, before the November 2026 milestone creates a bottleneck

The Bottom Line

DPDPA compliance will be judged on what your systems can actually prove, not what your privacy policy says. That makes it fundamentally a cybersecurity and infrastructure challenge, and the organisations that treat it that way now will be the ones not scrambling in 2027.

CoreGenix specialises in IT infrastructure, cloud security, and cyber risk assessments the technical backbone DPDPA compliance depends on. Get in touch to start your readiness audit.

References

[1] Shardul Amarchand Mangaldas & Co, "Enforcement of the DPDP Act and notification of the DPDP rules" — <https://www.amsshardul.com/insight/enforcement-of-the-dpdp-act-and-notification-of-the-dpdp-rules/>

[2] EY India, "DPDP Rules 2025 Notified by MeitY: Complete Guide" — https://www.ey.com/en_in/insights/cybersecurity/transforming-data-privacy-digital-personal-data-protection-rules-2025

[3] DLA Piper, "Data protection laws in India" — Data Protection Laws of the World — <https://www.dlapiperdataprotection.com/?t=law&c=IN>

[4] Apex Law Office LLP, "Digital Personal Data Protection Act 2023: Compliance & Data Breach Penalties 2026" — <https://legalfirm.in/digital-personal-data-protection-act-2023-compliance-data-breach-penalties-2026/>